学号	2112233069

广 州 大 学

硕士研究生学位论文开题报告

姓　　名：张晨晖

学　　号：2112233069

专业\领域：网络与信息安全

论文题目：基于威胁情报的靶标自动化生成研究

指导教师：王乐

是否保密：否

保密等级：

年　　月　　日填

填表说明：

1、表格要求统一以“小 4 号宋体”字体填写，双面打印，表格的格式和页码次序不能擅自改变，如需附页一律加在本表格后面，并注明前后接连地方；

2、所有栏目须填写清楚，不留空白，所有审核意见须填写具体、有针对性；

3、凡没有建立班组或系教研室的，基层组织意见或系教研室意见一律由学院主管院长负责填写：

4、签名必须由相应责任人签名，不得打印代替；

5、须盖学院公章的地方不能不盖；

6、本表一式三份，学院审核后，研究生本人留一份，学院留存一份，报研究生院一份。

学位论文题目	基于威胁情报的靶标自动化生成研究
经费来源	无

本研究题目是否属导师课题的一部分？如果是的话，属哪一部分？
否

学 位 论 文 的 类 型（在相应栏目划√）：

☐理论研究　　☑应用基础　　☐用于生产　　☐其他

一、立题依据（包括国内外研究现状和发展趋势、文献综述、研究目的、意义等）：

1.1 研究意义

随着互联网的发展，不同地域被紧密连接，网络上的信息交换愈发频繁，许多组织都依赖网络工作。而相对应的，网络犯罪的数量和复杂度也在激增，网络攻击所造成的经济、数据和名誉损失也愈发庞大。2022 年 6 月，西北工业大学公开声明遭遇境外黑客攻击，黑客采取半自动化攻击流程，单点突破、逐步渗透、长期窃密，窃取了账号口令，配置文件，人员信息等一系列敏感信息[1]。2023 年 11 月，ChatGPT 遭受黑客分布式拒绝服务（DDoS）攻击导致服务遭受了周期性中断。由此可见，组织迫切的需要提升网络安全能力以应对网络威胁，减少因网络攻击造成的损失。

网络靶场是一种对真实网络空间中的网络拓扑、系统版本、服务状态等环境进行仿真复现的设施，可以方便人员进行网络安全相关的学习和研究，提升网络安全能力。具体来说，网络攻击者可以在网络靶场上提升攻击技能而不用担心法律风险，网络防御者可以训练对抗攻击者的能力例如检测和溯源。攻防双方在靶场上演练，不断对抗演进，导致组织中参与演练的人员的攻防水平得到提升，组织对现实攻击的防御能力得到加强。而创建一个网络靶场是一项复杂的任务，涉及到靶场拓扑的构建，业务的选择，反馈和评估等工作，这些都需要专家耗费大量的时间和精力去完成。因此自动化的创建一个网络靶场能一定程度缩减组织在网络安全上的成本，降低组织使用靶场的门槛，对于网络安全能力的普及有着重要的作用。

自动化创建网络靶场时，威胁场景中靶标的自动生成就显得尤为重要。威胁场景是真实世界中可能发生的攻击模式和安全事件的模拟，需要考虑当前网络安全环境中的实际威胁，包括最新的攻击手段、常见的漏洞利用以及高级持续威胁攻击（APT 攻击）等。合适的威胁场景能够帮助演练人员有效提升攻防能力。而靶标是威胁场景中关键的基础设施。

由此，本课题研究在网络靶场环境中自动化生成靶标。它不直接涉及攻击手段或防御策略的具体模拟，而是提供基础设施，使得真实世界中的攻击活动可以在这些设施下被模拟。通过这种方式，安全人员可以在一个既安全又可控的环境中进行安全研究以及提升他们的攻防技术能力。

在现实中，攻击者的手法不断演变，由各大安全组织持续更新的威胁情报提供

了这些变化的窗口。通过这些报告，我们可以捕捉到攻击者的新策略、所利用的漏洞、以及他们的行为模式。将这些信息转化为靶场中威胁场景的靶标，能够确保训练环境与现实世界的威胁同步更新。通过这项研究，我们期望能够为网络安全人员提供一个动态的、能够不断演进的研究训练平台，提升他们对现有威胁的应对能力。

1.2 国内外研究现状

近年来，人们越来越意识到威胁场景设施和威胁情报在组织的网络安全能力提升中所发挥的重要作用，相关产品和研究应运而生。

在靶标构建方面方面，DVWA（Damn Vulnerable Web Application）是一个经典的 PHP/MySQL Web 开源靶场应用[2]，能够为网安人员测试和提高自己的攻击渗透能力提供合法的环境。Metasploitable3 是一个虚拟靶标系统，里面含有大量未被修复的安全漏洞，它主要用于提升安全人员对当前流行的攻击框架 Metasploit 的掌握能力[3]。Vulnhub 以真实的企业的企业环境为实例，模拟 ATT&CK 的攻击链路进行搭建，可以提升安全人员的内网攻击能力[4]。以上这些靶场采用的都是预定义的靶标和人工手动搭建部署，较为繁琐。为了减少搭建部署的工作量，业界普遍采用将靶标打造成镜像的方法，方便部署，做到开箱即用[5][6][7]。但其还是免不了人工预定义含漏洞的靶标。有许多研究致力于靶场的自动化构建[8][9][10][11],其中以下研究与自动化靶标生成较为相关。Francesco Caturano 等人提出了一个平台可以实现无需预先定义的，从公共漏洞利用信息中自动创建和配置漏洞靶标镜像的方法，但其只适用于 WordPress 应用程序[12]。S. Arshad 提出了一种 Mitre ATT&CK 框架的攻击特定语言，定义了攻击者技战术和靶标需要的平台、服务、和漏洞之间的联系[13]。遗憾的是，这种联系需要手动定义，组织依旧需要持续投入相当的成本以应对漏洞和攻击者技战术的演变。有以上研究可知，漏洞是靶标不可或缺的部分。

在威胁情报方面，一些研究者致力于从威胁情报中提取攻击行为，Kiavash Satvat 等人从威胁情报中依据语义角色标注和图构建的方法，生成攻击行为的起源图，可帮助威胁检测系统识别攻击[14]。Zhenyuan Li 等人聚合多个威胁情报中的攻击知识，建立攻击技术模板，将攻击者的行为与 ATT&CK 框架对齐[15]。类似的，TRAM 使用大语言模型分析威胁情报并且识别其中包含的 ATT&CK 技战术[16]。

由以上研究可知威胁情报包含中丰富的攻击行为信息。

在构建威胁情报和威胁场景设施的联系上，据我所知目前没有直接的研究，但有一些研究者致力于构建漏洞和攻击者的攻击行为之间的联系[17][18][19][20]。由前文所述，威胁场景设施与漏洞、威胁情报与攻击行为的密切联系，可知构建漏洞和攻击行为之间的联系可以帮助研究将威胁情报用于靶场中靶标的生成。

1.3 研究目的

基于构建自动化的智能靶场的需要，面向培训网安人才与还原现实中不断发生的攻击活动的需求，本课题提出基于威胁情报的靶场上靶标自动化生成，实现承载攻击活动的靶标生成，打通从威胁情报到靶标构建的全流程，达成两个目的，一是及时性，二是合理性。及时性体现在随着威胁情报的更新，本课题提出的系统可以根据威胁情报自动生成靶标。合理性体现在生成的靶标能够承载威胁情报中的攻击行为。

[1] 国家计算机病毒应急处理中心。西北工业大学遭美国 NSA 网络攻击事件调查报告（之二）。[在线] 可获取：https://www.cverc.org.cn/head/zhaiyao/news20220927-NPU2.htm. 2022。

[2] Damn Vulnerable Web Application（DVWA）。"致命的易受攻击的 Web 应用程序"。访问日期：2024 年 4 月 17 日。网址：<https://github.com/digininja/DVWA>。

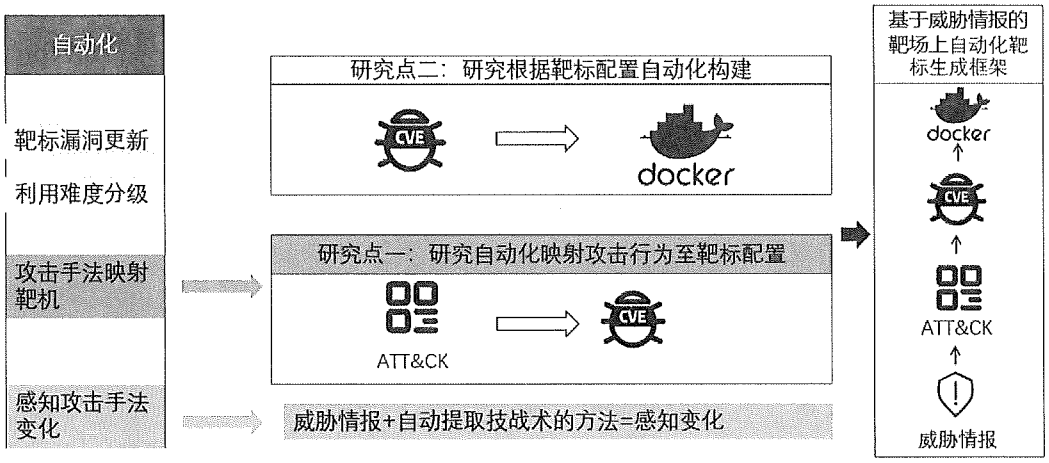
[3] Rapid7。metasploitable3。访问日期：2024 年 4 月 17 日。网址：<https://github.com/rapid7/metasploitable3>。
[4] 红日团队。红队实战测试环境。访问日期：2024 年 4 月 17 日。网址：<http://vulnstack.qiyuanxuetang.net/vuln/detail/2>。
[5] vulhub。面向大众的开源漏洞靶场。访问日期：2024 年 4 月 17 日。网址：<https://github.com/vulhub/vulhub>。
[6] vulapps。即开即用的漏洞环境与安全工具环境搭建。访问日期：2024 年 4 月 17 日。网址：<http://vulapps.evalbug.com/>。
[7] Metarget。云原生攻防靶场。访问日期：2024 年 4 月 17 日。网址：<https://github.com/Metarget/metarget>。
[8] Ear, E., Remy, J.L., & Xu, S. (2023). Towards Automated Cyber Range Design: Characterizing and Matching Demands to Supplies. 2023 IEEE International Conference on Cyber Security and Resilience (CSR), 329-334.
[9] Orbinato, V. (2021). A next-generation platform for Cyber Range-as-a-Service. 2021 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW), 314-318.
[10] Nakata, Ryotaro & Otsuka, Akira. (2021). CyExec*: Automatic Generation of Randomized Cyber Range Scenarios. 226-236. 10.5220/0010324502260236.
[11] Z. Cliffe Schreuders, Thomas Shaw, Mohammad Shan-A.-Khuda, Gajendra Ravichandran, Jason Keighley, Mihai Ordean: Security Scenario Generator (SecGen): A Framework for Generating Randomly Vulnerable Rich-scenario VMs for Learning Computer Security and Hosting CTF Events. ASE @ USENIX Security Symposium 2017
[12] F. Caturano, N. d' Ambrosio, G. Perrone, L. Previdente and S. P. Romano, "ExploitWP2Docker: a Platform for Automating the Generation of Vulnerable WordPress Environments for Cyber Ranges," 2022 International Conference on Electrical, Computer and Energy Technologies (ICECET), Prague, Czech Republic, 2022, pp. 1-7, doi: 10.1109/ICECET55527.2022.9872859.
[13] S. Arshad, M. Alam, S. Al-Kuwari and M. H. A. Khan, "Attack Specification Language: Domain Specific Language for Dynamic Training in Cyber Range," 2021 IEEE Global Engineering Education Conference (EDUCON), Vienna, Austria, 2021, pp. 873-879, doi: 10.1109/EDUCON46332.2021.9454094.
[14] Kiavash Satvat, et al. EXTRACTOR: Extracting Attack Behavior from Threat Reports. EurS&P' 21
[15] Zhenyuan Li, Jun Zeng, Yan Chen, and Zhenkai Liang. 2022. AttacKG: Constructing Technique Knowledge Graph from Cyber Threat Intelligence Reports. In Computer Security - ESORICS 2022: 27th European Symposium on Research in Computer Security, Copenhagen, Denmark, September 26 - 30, 2022, Proceedings, Part I. Springer-Verlag, Berlin, Heidelberg, 589 - 609. https://doi.org/10.1007/978-3-031-17140-6_29
[16] center-for-threat-informed-defense。TRAM。访问日期：2024 年 4 月 17 日。网址：<https://github.com/center-for-threat-informed-defense/tram>。
[17] Grigorescu, O., Nica, A., Dascalu, M., & Rughinis, R.V. (2022). CVE2ATT&CK: BERT-Based Mapping of CVEs to MITRE ATT&CK Techniques. Algorithms, 15, 314.

[18] Kuppa, Aditya, Lamine M. Aouad and Nhien-An Le-Khac. "Linking CVE's to MITRE ATT&CK Techniques." Proceedings of the 16th International Conference on Availability, Reliability and Security (2021): n. pag.
[19] Aghaei, Ehsan and Ehab Al-Shaer. "CVE-driven Attack Technique Prediction with Semantic Information Extraction and a Domain-specific Language Model." ArXiv abs/2309.02785 (2023): n. pag.
[20] Hemberg, Erik & Kelly, Jonathan & Shlapentokh-Rothman, Michal & Reinstadler, Bryn & Xu, Katherine & Rutar, Nick & O'Reilly, Una-May. (2020). BRON -- Linking Attack Tactics, Techniques, and Patterns with Defensive Weaknesses, Vulnerabilities and Affected Platform Configurations.

二、研究内容（说明课题的具体内容，独创及新颖之处，重点解决的问题，预期的研究成果）：

2.1 课题的具体内容

网络靶场的类型多种多样，每个组织对网络靶场的使用需求都不尽相同。组织在创建靶场时应根据自身需求和能力，明确靶场的目标和范围，完成靶场创建。本课题研究基于威胁情报的靶场上靶标自动化生成方法，方法应满足生成靶标的四个需求：靶标能感知从而适应变化的攻击手法，靶标能支持攻击者的攻击手法，靶标机器的漏洞保持更新，靶标利用难度不一。为满足这四个需求，研究自动的从威胁情报中提取攻击行为、自动的从攻击行为到靶场中靶标配置的映射、自动的对靶标包含的漏洞实现难度分级、自动的制作靶标镜像。如图一所示



图一

为了满足感知并适应攻击者威胁行为变化的需求，引入威胁情报作为感知攻击者行为的窗口，自动化提取技战术的方法作为感知的工具，将攻击者行为规范为技战术以满足后续研究需要。

在研究点一上，为满足靶机能支持攻击者的攻击行为的需求，研究自动化映射攻击行为至靶标配置，具体来说就是研究如何将 CVE 漏洞映射至 ATT&CK 所描述的攻击行为上。

在研究点二上，为满足靶标机器保持更新的需求，研究靶标的虚拟环境的自动化构建。前期的调研发现，现有的靶标机器依赖人工预定义。因此本课题研究从 CVE 漏洞到 Docker 虚拟环境的自动化构建。为满足靶标机器利用难度的不一的需求，研究靶标机器包含漏洞的自动化难度分级。

2.2 研究创新点和重点解决问题。

本课题的创新点主要在首次提出并初步达成从威胁情报到靶场上靶标机器生成的全流程框架，重点解决创建靶标机器的自动化方法，具体如下：

(1) 使用思维链方法微调大语言模型以提高从攻击行为到设施中漏洞映射的准确率

(2) 结合 CVE 和 CPE，基于 docker 自动化构建设施中靶标的镜像

(3) 建立模型预测漏洞的可利用性，结合预测方法，对靶标包含漏洞做难度分级，丰富靶标漏洞类型，使靶标中包含不可轻易利用的漏洞，更加贴合现实场景

2.3 预期成果。

1、发表基于公开利用信息的漏洞难度分级论文一篇

2、发表基于威胁情报的靶场上自动化靶标生成专利一篇

3、实现基于威胁情报的靶场上自动化靶标生成系统

三、科研方案设计（包括：研究方法、技术路线、理论分析、计算、实验方法和步骤及其可行性，可能出现的技术问题及解决方法）：

3.1 研究方法和技术路线。

本课题采取工程技术方法，根据多阶段的实验达成研究目的。使用模拟的研究方法，以攻击行为和含漏洞漏洞靶标为载体，模拟承载攻击活动。主要使用 python 编程语言，自然语言处理方法，分析威胁情报，漏洞数据库，漏洞利用数据库等开源的信息，探究并补全它们之间的联系，保障模拟的及时性和合理性。

在技术路线上，分为三个步骤说明，一、从威胁情报到攻击行为，意为提取并规范威胁情报中包含的攻击行为，方便面对不同源、不同格式、不同信息量的威胁情报。二、从攻击行为到威胁场景设施中的漏洞靶标配置，意为建立从攻击行为到受攻击的设施之间的联系，值得一提的是，受攻击的服务和设施不可胜数，考虑到用于网安训练目的，只需尽可能合理且能帮助训练即可。三、从靶标配置到实际镜像的构建，意为通过虚拟化的环境方便漏洞环境的复现。

针对第一个步骤的从威胁情报中提取攻击行为，采取以下的技术路线。以业界流行的 ATT&CK 框架为标准，在威胁情报报告中标注攻击者的技战术，以用作模型训练数据和微调大语言模型。使用大语言模型的好处是，它在大量数据上进行了预训练，所以它们需要更少的特定于领域的训练数据来达成目的。

针对第二个步骤的从攻击行为到靶标配置，采取以下的技术路线。根据第一个步骤提取到的 ATT&CK 技战术，研究建立漏洞到技战术的映射关系。之前的研究要么根据漏洞知识库，弱点知识库，攻击模式

知识库，技战术知识库之间的联系，建立映射；要么根据文本分类模型，以漏洞描述作为输入，技战术分类作为输出，建立联系。本研究预计使用思维链方法微调语言模型，通过思维链引入拓扑关系，提升使用语言模型建立映射的效果。

针对第三个步骤的从靶标配置到实际镜像的构建，采取以下的技术路线。以漏洞利用的难易程度为分类，建立不同难度的靶标镜像。满足不同等级安全人员的训练要求。在靶机的难度分类上，参考现有的关于漏洞可利用性预测的工作，将漏洞描述，CVE 漏洞发布时间，漏洞利用数据库对 CVE 漏洞的利用代码的发布时间作为训练材料，训练预测模型，达成根据漏洞描述预测漏洞可利用性和利用时间的长短的效果；在靶机镜像的构建上，使用实体识别的方法从 CVE 描述中抽取漏洞版本，结合 CPE 和各大开源软件库以及开源平台，根据规则生成 dockerfile 文件，自动化包含漏洞版本的 docker 靶标构建。

3.2 潜在技术问题及解决方法

（1）技术问题：

漏洞预测器无法根据漏洞描述对漏洞做到难度分类，或分类准确率极低

（2）解决办法：

可以考虑使用结合已有的漏洞可利用性的工作，先预测出漏洞的可利用性，再根据国际通用的漏洞评分标准（CVSS），以引入知识库的方式对漏洞做难度分类

学 位 论 文 工 作 计 划

时 间	研 究 内 容	预期效果
2024.5-2024.8	设计靶标构建实验方案，调研并复现更好的威胁行为抽取方法，实现构建模块	完成靶标构建实验设计报告和威胁行为抽取，实现靶标构建模块
2024.9-2024.11	继续完善框架设计，学习漏洞利用预测原理.实现难度分级模块	完成框架设计，撰写相关论文
2024.12-2025.2	实验实现整体设计方案	实现基于威胁情报的靶场上自动化靶标生成系统 完成专利撰写
2025.2-2025.4	毕业论文撰写及答辩 PPT 制作	完成论文及答辩 PPT

论文工作起止日期	2024.03-2025.04	预计论文答辩日期	2025.05

科研经费开支计划

低值设备仪器名称	数 量	金 额	项 目	金 额
无	无	无	试验材料费 试剂药品费 旅 差 费 资 料 费 其 它	无

合计金额：0 元

开题报告人签名：张晨晖　　年　月　日

广州大学研究生学位论文开题报告审核表

研究生姓名	张晨晖	导　　师	王乐
专业\领域	网络与信息安全	研究方向	靶场自动化生成
论文题目：基于威胁情报的靶标自动化生成研究			
开题报告时间：**2024** 年 **4** 月 **29** 日		开题报告地点：**B3-411**	

开题报告审核小组

组成	姓名	职称	所在单位	成员签名
组长	李树栋	教授	广州大学	李树栋
成员	唐可可	副教授	广州大学	唐可可
	冯绮颖	副教授	广州大学	冯绮颖

开题报告中提出的主要问题及回答的简要情况：

问题：参考文献的引用不应该加粗，章节序号不正确，应当在报告中适当添加图片解释，全是文字难以理解。**PPT** 上画的图可以改成黑白的迁移到报告上。

回答：会在之后修改。

现状：已修改格式并重新调整了报告逻辑，使其更易于理解。

问题：题目是基于威胁情报的靶场上靶标自动化生成研究，“靶场上”是否可以去掉，因为靶标本身就是在靶场上的。

回答：之前命名考虑到突然引入靶标有点突兀，靶场和靶标确实是一个领域的概念可以省去。

现状：已经修改题目为基于威胁情报的靶标自动化生成研究

记录人签名：

年　　月　　日

审核小组意见：（开题报告审核小组就论文选题意义及创新点，国内、外相关文献掌握程度和研究方法的可靠性，论文总体设计的科学性和可行性，存在的主要不足等提出意见或修改建议。）

开题报告中详细说明了论文选题的研究意义、目的、研究内容和研究的预期成果，论文选题总体合理，有较好的实践意义，相关研究准备较为充分，研究目标清晰，研究方法和技术路线较为科学可行。但还存在着一些不足，报告格式混乱需要修改，全是文字难以理解，需要配上相关的图。题目文字赘余可以适当精简。

建议：1、通过。

2、不通过，建议 1 个月内重新进行开题报告审核或终止学业。

组长签名：

（不够写可加附页）　　年　月　日

学院审查意见：

同　意

主管领导签名：　　（公章）

年　月　日

广州大学研究生院制表